

A Sleight-of-Hand Getshell

By RG · Translated from the Chinese original

0x00 Preface

One day, while testing a vendor's business systems, I found an asset that offered a music streaming service — and it happened to have a song I wanted to hear. That's how this article was born.

[Martin Garrix]的相关音乐

1 David Guetta Martin Garrix Vs Brooks - Like I Do (Nicky ...

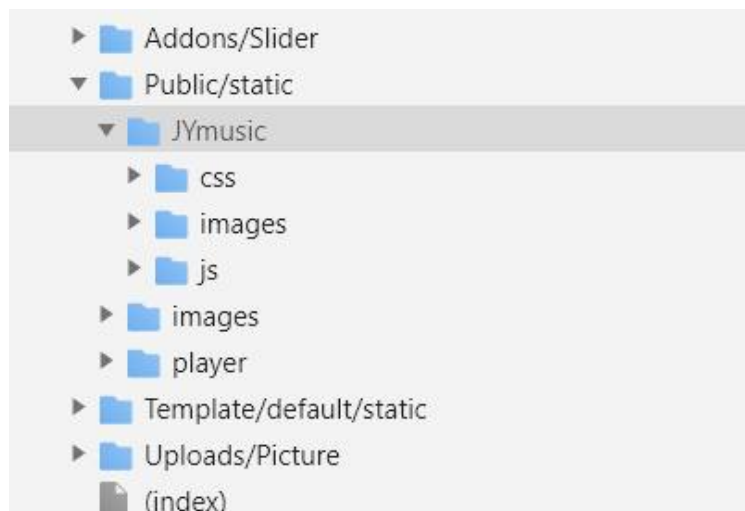
2 Martin Garrix, David Guetta - So Far Away (CliQ Remix)

0x01 Information Gathering

A quick F12 to check the target's environment:

Server: IIS 7.5
CMS: JYMusic (ThinkPHP)

```
<!--[if IE 9 ]><html class="ie9" lang="en"><![endif]--><!--[if (gt IE
equiv="Content-Type" content="text/html; charset=UTF-8"><meta name="viewport" content
name="author" content="JYmusic音乐管理系统"><meta name="keywords" content="DJ舞曲,DJ
工作者及音乐爱好者的需求。"><link type="image/x-ico; charset=binary" rel="JYmusic ico
```



▼ **Response Headers** [view source](#)

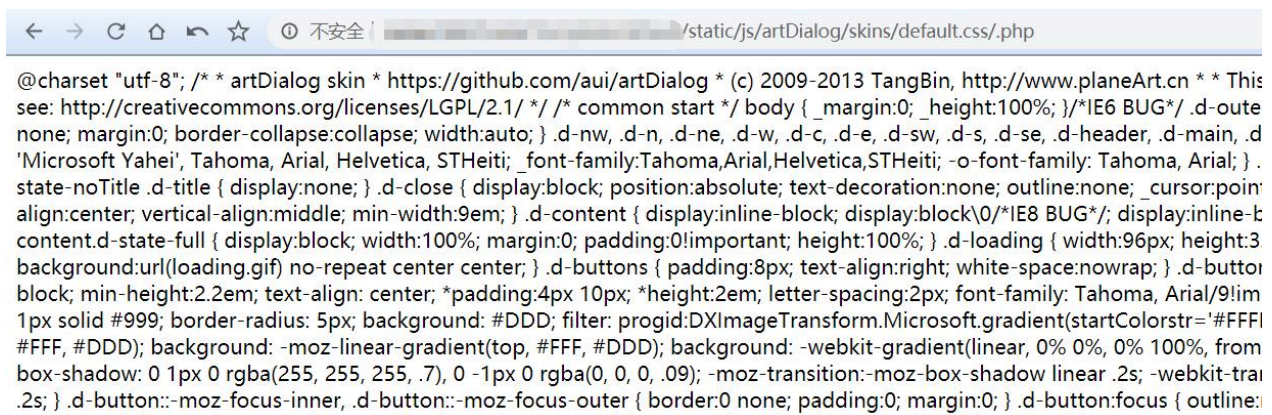
```

Cache-Control: private
Content-Encoding: gzip
Content-Length: 15989
Content-Type: text/html; charset=utf-8
Date: Sat, 05 Dec 2020 08:06:41 GMT
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Pragma: no-cache
Server: Microsoft-IIS/7.5
Vary: Accept-Encoding
X-Powered-By: ThinkPHP
X-Powered-By: ASP.NET

```

0x02 Getting Started, and Hitting a Wall

In a let's-see-what-happens mood, I picked a random resource file and tried a parsing vulnerability — and to my surprise, it worked. Now all I needed was an upload point to get a shell.



The usual editor suspects:

```

Ueditor / Ueditor
Kindeditor
ckeditor / ckfinder

```

```

program upload points:

```

```

avatar / article / attachment ... upload components

```

The target site had open registration. After logging in I found an avatar upload — I thought it was over already, but no dice: the images were clearly being re-rendered (secondary rendering)...

```

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml"><head>
<meta content="text/html; charset=utf-8" http-equiv="Content-Type">
<title>系统发生错误</title>
<style type="text/css">
*{ padding: 0; margin: 0; }
html{ overflow-y: scroll; }
body{ background: #fff; font-family: '微软雅黑'; color: #333; font-size:
16px; }
img{ border: 0; }
.error{ padding: 24px 48px; }
.face{ width:320px; margin:20px auto; }
.face img {width:320px; }
h1{ font-size: 32px; line-height: 48px; text-align:center; }
.error .content{ padding-top: 10px}
.error .info{ margin-bottom: 12px; }
.error .info .title{ margin-bottom: 3px; }
.error .info .title h3{ color: #000; font-weight: 700; font-size: 16px;
}
.error .info .text{ line-height: 24px; }
.copyright{ padding: 12px 48px; color: #999; margin:0 auto; width:220px}
.copyright a{ color: #000; text-decoration: none; }
</style>
</head>
<body>
<div class="error">
<p class="face"></p>
<h1>你访问的页面不存在~</h1>
<div class="content" style="margin:0 auto">
</div>
</div>
<div class="copyright" >
<p><a title="官方网站" href="http://www.jyuu.cn">JYmusic</a><sup></sup>[ php
音乐管理程序 ]</p>

```

I tried webshells that survive image re-rendering, but still couldn't get a proper shell. Time to give up on the avatar feature.

0x03 A Silver Lining

With the avatar upload road blocked, I had to find another way out. The share-music feature had been switched to manual review, but I guessed the underlying interface still existed.



Through FOFA I found another site where the feature still worked normally. Call it www.bbb.com.

That site's share-music function worked as intended.

分享音乐

上传条款

上传音乐，即表示您已同意 [上传服务条款](#)，请勿上传色情及反动等违法音乐,单个文件最大20MB

音乐名称*

合理的名字才会通过审核

所属分类*

选择曲风

所属专辑*

单曲

如果没有请点击添加专辑

上传音乐*

点击上传

点击或将文件拖拽到此处

歌曲歌词

支持LRC歌词和文本歌词

Upload a music file directly:



The file uploaded fine, but no path was returned — hmm. Submit anyway and see.

WTF — "no category data"? No problem: bring out the mighty F12, add an option with a value to the select tag.

```

<select class="form-control" error="" name="get"
  <option value="">选择曲风</option>
  <option value="123">测试</option>

{
  "info": "分享成功, 请等待审核...",
  "status": 1,
  "url": "/index.php?s=/user/music/audit.html"
}

```

"Share successful." It showed up in the review queue too. Editing it revealed ID 23; clicking randomly into one from the homepage showed ID 21.



I also noticed an interface that returns the uploaded music's file path. Swap in ID=23 and the path is yours.

Name

index.php?s=/music/getdata.html

index.php?s=/Member/getUser.html

logo@2x.png

logo@2x.png

avatar@2x.png

▼ {id: "21", server_id: "0", name: "《当我谈跑步时, 我谈些什么》", artist_id: "4", artist_name: "id: "21", server_id: "0", name: "《当我谈跑步时, 我谈些什么》", artist_id: "4", artist_name: "小创", album_id: "0", album_name: "", cover_url: "/Public/static/images/cover.png", up_uid: "1", up_username: "admin", lrc: "本书是村上春树最受欢迎的随笔集。开始作家生涯之际, 村上春树也开始长跑。从夏威夷的考爱岛, listen_url: "https://06/170249_23_oh1h.mp3"

URL

http://.../index.php?s=/music/getdata.html

Enable POST

application/x-www-form-urlencoded

ADD HEADER

Body

id=23

X-Requested-With

XMLHttpRequest

And there was the idea: replay the whole www.bbb.com procedure on www.aaa.com.

English edition · translated from the Chinese original; figures unchanged

5

Take the music-upload request from bbb.com and graft it onto aaa.com (in Burp, rewrite the Host and Cookie; change the fileid on submit).



Access our MP3-extension webshell through the parsing vulnerability:

And with that — shell obtained.

[illegible]

PHP Version 5.4.37	
System	Windows NT MIX57COM 6.1 build 7601 (Windows Server 2008 R2 Enterprise Edition Service Pack 1) i586
Build Date	Jan 21 2015 01:56:45
Compiler	MSVC9 (Visual C++ 2008)
Architecture	x86
Configure Command	<pre>cscript /nologo configure.js "--enable-snapshot-build" "--enable-debug-pack" "--disable-zts" "--disable-isapi" "--disable-nsapi" "--without-mssql" "--without-pdo-mssql" "--without-p3web" "--with-pdo-oci=C:\php-sd\oracle\instantclient10sdk" "--with-oci8=C:\php-sd\oracle\instantclient10sdk\shared" "--with-oci8-11g=C:\php-sd\oracle\instantclient11sdk\shared" "--with-ehant=shared" "--enable-object-out-dir=/obj/" "--enable-com-dotnet=shared" "--with-mcrypt=static" "--disable-static-analyze" "--with-pgsql"</pre>
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File	C:\Windows